Exception Request (Waiver) – TRB Policy Override

Document control	
Document ID	EXC-2026-001
Document type	Exception Request
Date	2026-08-20
Status	Denied
Review IDs	TRB-2026-003
Feature keys	SQL Server (cloud + on-prem)@Ingestion
Classification	Internal – Synthetic Sample

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

Exception ID: EXC-2026-001
Requestor: [Finance Director], Finance Department
Date Submitted: August 20, 2026
Urgency: [ ] Standard (30 days) | [x] Expedited (14 days) | [ ] Emergency (72 hours)

---

1. What is Being Requested?

Feature Name:
SQL Server Connector (Cloud + On-Prem)

Current TRB Status:
Approved – Non-PHI only (TRB-2026-003, approved July 14, 2026)

Exception Request:
We request a **phased waiver** to use SQL Server Connector with **limited PHI scope** (member name + ID only, non-sensitive PHI) for the **annual member reconciliation project** before the feature reaches GA.

Specific Override:
Normally, SQL Server Connector is approved for non-PHI data only (claims counts, amounts, dates—no member identifiers). We are asking TRB to allow **member name +**

ID (linked reconciliation) for the reconciliation process. This is non-sensitive PHI under HIPAA (name + member ID, without diagnosis/medical data), but expands beyond the current non-PHI-only scope.

---

2. Business Justification

Why is this request important to Acme Health Plan?

Our annual Financial Reconciliation process compares member claims in Databricks against the legacy SQL Server claims system. This ensures accuracy, detects data entry errors, and supports financial audit compliance.

Current Process (Manual):
- Finance team exports claim data from both systems
- Manually matches claims using member ID + DOS + claim amount (no member names, to avoid PHI exposure)
- Manual matching is error-prone; ~2% of claims require manual investigation
- Process takes 6 weeks; requires 2 FTE Finance analysts
- High risk of human error; audit findings cite reconciliation delays

Proposed Process (Automated via SQL Server Connector):
- Query both Databricks and SQL Server using member name + ID as matching key
- Automated join; validates amounts match
- Identifies discrepancies in <1 day
- Reduces FTE from 2 to 0.5
- Higher accuracy; audit-friendly

Business Impact:
- Cost savings: ~$100K/year (1.5 FTE reduction)
- Accuracy improvement: Reduce reconciliation errors from 2% to <0.1%
- Timeline: Complete by December 31, 2026 (fiscal year-end audit deadline)
- Strategic: Enables annual audit sign-off on schedule

Key Success Metrics:
- Reconciliation completed by Dec 31, 2026 ✓
- Zero PHI breaches during pilot ✓
- Audit findings: "Reconciliation controls improved" ✓

---

3. Risk Analysis

What TRB decision are you asking to override?

We are asking TRB to approve use of member **name + ID** (considered PHI under HIPAA when combined), which exceeds the current approval (non-PHI only: claims counts, dates, amounts).

Proposed Mitigation

Overridden Control	Original Risk	Proposed Mitigation	Residual Risk	Acceptability
SQL Server Connector approval limited to non-PHI data (no member identifiers)	Uncontrolled PHI exposure; unclear audit trail for member-specific queries	Pilot scope: 1000 members only; member name + ID only (no SSN, DOB, diagnosis). Access by 2 Finance analysts only (trained). Quarterly audit by Finance director. 90-day pilot window.	Low—scope is narrow, no sensitive PHI, short duration	[x] Acceptable
No direct member name visibility (reconciliation currently uses member ID as join key, then validates by amount/date)	Error rate ~2%; manual matching inefficient	Automated join using name + ID; allows QA validation by Finance director (spot-checks 5% of matched pairs). Finance director certifies accuracy.	Low—human review ensures accuracy	[x] Acceptable
SQL Server security (on-prem customer systems)	Exposure if on-prem server not hardened; no direct Acme controls	On-prem SQL Server connection will use TLS 1.2+ (customer certifies). Access limited to stored procedure (read-only, no direct table access). IP allowlist: Databricks workspace IP only.	Low—restrictive access; TLS encryption	[x] Acceptable

Risk Acceptance Statement:
Finance Department understands the risk and accepts responsibility for pilot

management. Finance commits to:
- Daily logs review by Finance Director
- Escalation to CISO within 1 hour if any unauthorized query detected
- 100% audit of exported data (if any) to ensure no PHI outside workspace
- Suspension of pilot if any incident occurs

---

4. Timeline & Scope

Project / Use Case:
Annual Member Financial Reconciliation for fiscal year-end audit (December 31, 2026 deadline)

Duration Needed:
- Start: September 1, 2026 (setup + testing)
- End: December 31, 2026 (audit deadline)
- Rationale: Must complete by year-end for financial audit closing

Users Affected:
- Count: 2 Finance analysts (no other users)
- Roles: [Senior Financial Analyst], [Financial Analyst]
- Training Status: 2/2 completed HIPAA training (certs attached)

Data Scope:
- **Data Elements:** Member name, member ID, claim ID, DOS (date of service), claim amount
- **NO:** SSN, DOB, diagnosis, provider NPI, clinical codes
- **Row Count:** ~1,000 members selected for detailed reconciliation (top claims by volume; strategic business units)
- **Sensitivity:** Member name + ID = PHI (HIPAA), but **non-sensitive PHI** (no medical content); used for data matching, not clinical purposes
- **Query Pattern:** 2–3 queries per day during pilot; all from Databricks workspace (no export)

Example Query:

```
SELECT
  datalake.members.member_id,
  datalake.members.member_name,
  COUNT(datalake.claims.claim_id) as claim_count,
  SUM(datalake.claims.claim_amount) as total_amount
FROM legacy_sql_server.claims cs
INNER JOIN datalake.members ON cs.member_id = datalake.members.member_id
WHERE datalake.members.member_id IN (SELECT member_id FROM [list of 1000 reconciliation m
GROUP BY datalake.members.member_id, datalake.members.member_name
```

5. Conditions Offered by Requestor

What is the requestor willing to do to make this lower-risk for TRB?

Con-dition #	Offering / Commitment	Verification	Duration
1	Enhanced audit logging—Finance Director reviews ALL reconciliation queries daily (not just spot-checks). Screenshots + log summary sent to [Compliance Officer] daily.	Daily query audit logs. Compliance Officer spot-checks 3 logs per week.	Entire 90-day pilot (Sept 1 – Dec 31)
2	Automated data masking—Query results displayed in encrypted, secure Finance dashboard (no raw export to CSV/Excel). Finance Director verifies no copy-paste of raw data.	Dashboard access controls verified by TRB. Finance Director signs attestation weekly.	Entire pilot
3	Incident escalation—If ANY unauthorized query or data anomaly detected, Finance Director escalates to CISO within 1 hour. Pilot suspended pending investigation.	Incident log maintained; escalation confirmed by CISO.	Entire pilot
4	Limited user access—Only 2 Finance analysts granted access; no sharing of credentials; access revoked if analyst leaves department.	Access control list maintained by Platform Eng; reviewed monthly by TRB.	Entire pilot
5	User agreement—Both Finance analysts sign data handling agreement acknowledging HIPAA rules, data security, confidentiality, incident reporting.	Signed agreements filed; renewed if analysts change.	Entire pilot
6	Monthly reporting—Finance Director provides monthly report to TRB: queries executed, data accessed, any incidents, compliance status.	Report template provided by TRB; submitted by 5th of month.	Monthly during pilot + 30 days post-pilot

6. Compliance Certification

Requestor Attestation:

I certify that:
- ✓ The business justification above is accurate to the best of my knowledge.
- ✓ I have authority to commit the Finance Department to the mitigation conditions listed above.
- ✓ I have reviewed the TRB Charter and understand HIPAA PHI regulations and Acme Health Plan policy.
- ✓ I accept responsibility for monitoring and escalating compliance issues during this 90-day pilot period.
- ✓ I confirm Finance staff will complete the data handling user agreement.

Signature:
[Finance Director Name / Title]
Finance Director, Acme Health Plan
_____ Date: August 20, 2026

---

7. Supporting Documentation

Attach or reference:
- [x] Risk assessment: Custom risk analysis above (specific to this use case)
- [x] Project charter: Annual Financial Reconciliation SOP (URL: [Finance Wiki Link])
- [x] Executive approval: CFO email approval (forwarded; CFO confirms business need)
- [x] Training certificates: HIPAA training completion certs for 2 analysts (attached)
- [x] Data handling user agreement: Template attached; signatures to be collected

---

For TRB Use Only

Field	Value
TRB Review Meeting	TRBM-2026-09-08
TRB Lead Reviewer	[Enterprise Architect]
Exception Status	[ ] Approved
Expiration Date	December 31, 2026 (auto-expires)
Sunset Trigger	[x] Manual review at [Dec 15, 2026]

TRB Vote & Rationale

Board Vote (September 8, 2026, 10:00 AM ET):

Member	Vote	Notes
CISO	✗ Deny	SQL Server Connector is Public Preview; cannot carry PHI
CPO	✗ Deny (async concurrence)	Public Preview lacks SLA and maturity for PHI production use
Enterprise Architect	✗ Deny	Feature must reach GA before TRB can consider PHI scope
Platform Eng Lead	✗ Deny	Public Preview is out of compliance scope per TRB charter
Data Governance Lead	✗ Deny (abstained from vote due to conflict)	Requestor's department; does not vote
Compliance Officer	✗ Deny	HIPAA compliance scope excludes Public Preview features
Other: [CFO / Executive Rep]	✗ Deny	Business case understood, but cannot approve out-of-scope feature

Result: DENIED (6 members voted; 6 in favor of denial, 0 opposed, 1 abstained, 1 excused)

Denial Rationale:

Per TRB charter and HIPAA compliance framework, **Public Preview features are subject to compliance restrictions and cannot carry PHI.** Member name + member ID is PHI under 45 CFR § 164.102. The SQL Server Connector's Public Preview status means:
- No contractual SLA; support is "best effort"
- No maturity guarantees; feature may change or be deprecated
- Insufficient testing/hardening for production PHI handling

Alternatives Offered:

1. **Use approved GA path:** Row Filters & Column Masks (TRB-2026-001, already approved for PHI) can enforce member data filtering on a Databricks SQL table. Perform reconciliation using already-approved masking + filtering capabilities.
2. **Wait for GA:** When Databricks advances SQL Server Connector to GA, resubmit both a TRB feature review (for standard PHI scope) AND a new exception request (if still needed). At that time, with GA SLA and maturity, TRB will reassess.

Finance Department's business case is noted and appreciated. The denial is based on feature maturity, not business priority.

Exception Denied By:

[CISO Name], Chief Information Security Officer
Signature: _____ Date: September 8, 2026

[CPO Name], Chief Privacy Officer
Signature: _____ Date: September 8, 2026

Appeal Process

Appeal of Denial: Finance Director may appeal this denial if:
- Databricks advances SQL Server Connector to GA (submit new feature review request)
- Finance can propose an alternative using already-approved features (Row Filters & Column Masks)

Appeals must be submitted to the CISO with new evidence or changed circumstances. The decision to deny is final until one of the above conditions is met.

Next Steps for Finance:

1. Coordinate with Enterprise Architect to evaluate Row Filters & Column Masks as alternative for reconciliation
2. Monitor Databricks roadmap for SQL Server Connector GA release
3. If GA released, contact TRB to schedule feature review + potential exception re-submission

---

Classification: Internal – Synthetic Sample

Related Documents:
- TRB-2026-003 Original Decision: [Link to DR-2026-003]
- TRB Charter: [Link to Charter]
- Audit Trail: [Link to audit logs repository]